



Title: Security Assessment Using Open Source Penetration Testing Tools

1. Objective

The purpose of this task was to perform practical security assessment using multiple cybersecurity tools available in Kali Linux. The objective included reconnaissance, scanning, vulnerability detection, traffic interception, SQL injection testing, anonymization testing, and binary analysis.

2. Tools Used

- Nmap
 - theHarvester
 - Recon-ng
 - OWASP ZAP
 - sqlmap
 - Metasploit Framework
 - Tor
 - Proxychains
 - radare2
 - GDB
 - Docker
 - OWASP Juice Shop
-

3. Reconnaissance Using Nmap

The first phase involved scanning a target host to identify open ports and active services.

Command Used:

nmap -sV localhost



```
(kali@kali:~/Downloads)
$ sudo nmap -sV localhost
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-01 21:25 IST
Nmap scan report for localhost (127.0.0.1)
Host is up (0.0000050s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 995 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
631/tcp   open ipp            CUPS 2.4
902/tcp   open ssl/vmware-auth VMware Authentication Daemon 1.10 (Uses VNC, SOAP)
3000/tcp   open ppp?
3306/tcp   open mysql        MySQL 8.4.6
5432/tcp   open postgresql    PostgreSQL DB 9.6.0 or later
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service
SF-Port3000-TCP:V=7.95I=72D=4/1%Time=69CD400E%P=x86_64-pc-linux-gnu%r(Get
SF:Request,101B9,"HTTP/1.1\x20200\x200K\r\nAccess-Control-Allow-Origin:\x
SF:20*\r\nX-Content-Type-Options:\x20nosniff\r\nX-Frame-Options:\x20SAMEO
SF:RIGIN\r\nFeature-Policy:\x20payment\x20'self'\r\nX-Recruiting:\x20/#jo
SF:bs\r\nAccept-Ranges:\x20bytes\r\nCache-Control:\x20public,\x20max-age=0
SF:\r\nLast-Modified:\x20Wed,\x2001\x20Apr\x202026\x2015:49:13'\x20GMT\r\nE
SF:Tag:\x20W/\x20124fa-19d49bc0afe/\r\nContent-Type:\x20text/html;\x20chars
SF:et=UTF-8\r\nContent-Length:\x2075002\r\nVary:\x20Accept-Encoding\r\nDat
SF:e:\x20Wed,\x2001\x20Apr\x202026\x2015:55:58'\x20GMT\r\nConnection:\x20cl
SF:ose\r\n\r\n<!--\n\n\x20\x20\x20Copyright\x20(c)\x202014-2026\x20Bjoern
SF:\x20Kjiminich\x20\x20the\x20OWASP\x20Juice\x20Shop\x20contributors.\n
SF:\x20\x20\x20\x20SPDX-License-Identifier:\x20MIT\n\n\x20\x20-->\n\n<!doctype>\
SF:\x20html>\n<html\x20lang="en"\x20data-beasties-container>\n<head>\n\x2
SF:0\x20meta\x20charset="utf-8">\n\n\x20\x20<title>OWASP\x20Juice\x20Shop
SF:</title>\n\n\x20\x20meta\x20name="description"\x20content="Probably\x
SF:20the\x20most\x20modern\x20and\x20sophisticated\x20insecure\x20web\x20a
SF:pplication">\n\n\x20\x20meta\x20name="viewport"\x20content="width=de
SF:vice-width,\x20initial-scale=1">\n\n\x20\x20<link\x20id="favicon"\x20r
SF:el="icon"\x20">%r(HELP,2F,"HTTP/1.1\x20400\x20Bad\x20Request\r\nConn
SF:ection:\x20close\r\n\r\n")%r(NCP,2F,"HTTP/1.1\x20400\x20Bad\x20Request
SF:\r\nConnection:\x20close\r\n\r\n")%r(HTTPOptions,EA,"HTTP/1.1\x20204\x
SF:20No\x20Content\r\nAccess-Control-Allow-Origin:\x20*\r\nAccess-Control
SF:-Allow-Methods:\x20GET,HEAD,PUT,PATCH,POST,DELETE\r\nVary:\x20Access-Co
SF:ntrol-Request-Headers\r\nContent-Length:\x200\r\nDate:\x20Wed,\x2001\x2
SF:0Apr\x202026\x2015:55:58'\x20GMT\r\nConnection:\x20close\r\n\r\n")%r(RTS
SF:PRequest,EA,"HTTP/1.1\x20204\x20No\x20Content\r\nAccess-Control-Allow-
SF:Origin:\x20*\r\nAccess-Control-Allow-Methods:\x20GET,HEAD,PUT,PATCH,PO
SF:ST,DELETE\r\nVary:\x20Access-Control-Request-Headers\r\nContent-Length:
SF:\x200\r\nDate:\x20Wed,\x2001\x20Apr\x202026\x2015:55:58'\x20GMT\r\nConne
SF:ction:\x20close\r\n\r\n");
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.68 seconds
```

Observation:

The scan identified publicly exposed services such as HTTP and SSH running on the target host. This demonstrates how Nmap helps in initial network reconnaissance and service identification.

4. Email and Domain Intelligence Using theHarvester

TheHarvester was used to collect publicly available domain-related intelligence.

Command Used:

theHarvester -d google.com -b bing





Commands Used:

```
recon-ng
marketplace search whois
modules load recon/domains-hosts/bing_domain_web
options set SOURCE google.com
run
```

```
(AKNINJA@KALI)-[~/Downloads]
$ recon-ng
[*] Version check disabled.

Sponsored by...
// // BLACK HILLS // //
// // BLACK HILLS // //
www.blackhillsinfosec.com

PRACTISEC
www.practisec.com

[recon-ng v5.1.2, Tim Tomes (@lanmaster53)]

[1] Recon modules
[recon-ng][default] > marketplace install recon/domains-hosts/hackertarget
[*] Module installed: recon/domains-hosts/hackertarget
[*] Reloading modules...

[recon-ng][default] >
[recon-ng][default] > modules load recon/domains-hosts/hackertarget
[recon-ng][default][hackertarget] > options set SOURCE nmap.org
SOURCE => nmap.org
[recon-ng][default][hackertarget] > run

----- Nmap and C Library
NMAP.ORG
----- Non-Dirb Basics
[*] Country: None
[*] Host: ack.nmap.org
[*] Ip_Address: 50.116.1.184
[*] Latitude: None
[*] Longitude: None
[*] Notes: None
[*] Region: None
[*] -----
[*] Country: None
[*] Host: changeme.nmap.org
[*] Ip_Address: 50.116.1.184
[*] Latitude: None
[*] Longitude: None
[*] Notes: None
[*] Region: None
```



```
[*] Region: None
[*] -----
[*] Country: None
[*] Host: changeme.nmap.org
[*] Ip_Address: 50.116.1.184
[*] Latitude: None
[*] Longitude: None
[*] Notes: None
[*] Region: None
[*] -----
[*] Country: None
[*] Host: issues.nmap.org
[*] Ip_Address: 50.116.1.184
[*] Latitude: None
[*] Longitude: None
[*] Notes: None
[*] Region: None
[*] -----
[*] Country: None
[*] Host: scanme.nmap.org
[*] Ip_Address: 45.33.32.156
[*] Latitude: None
[*] Longitude: None
[*] Notes: None
[*] Region: None
[*] -----
[*] Country: None
[*] Host: svn.nmap.org
[*] Ip_Address: 50.116.1.184
[*] Latitude: None
[*] Longitude: None
[*] Notes: None
[*] Region: None
[*] -----
[*] Country: None
[*] Host: www.nmap.org
[*] Ip_Address: 50.116.1.184
[*] Latitude: None
[*] Longitude: None
[*] Notes: None
[*] Region: None
[*] -----
[*] Country: None
[*] Host: www.nmap.org
[*] Ip_Address: 50.116.1.184
[*] Latitude: None
[*] Longitude: None
[*] Notes: None
[*] Region: None
[*] -----
SUMMARY
-----
[*] 7 total (7 new) hosts found.
[recon-ng][default][hackertarget] > |
```

Observation:

Recon-ng generated structured reconnaissance data by using modular enumeration techniques. It allows systematic domain investigation and OSINT collection.



Verification Command:

docker ps

```
└─$ sudo docker ps
CONTAINER ID   IMAGE                  COMMAND                  CREATED        STATUS        PORTS                               NAMES
3cd7c13314b8   bkimminich/juice-shop  "/nodejs/bin/node /j_..."  20 minutes ago Up 20 minutes  0.0.0.0:3000->3000/tcp, :::3000->3000/tcp  eloquent_swirles
```

Observation:

The container started successfully and exposed the application locally on port 3000. The application became accessible through <http://127.0.0.1:3000>.

8. SQL Injection Testing Using sqlmap

SQLMap was used to test the local application for SQL injection possibilities.

Command Used:

sqlmap -u "<http://127.0.0.1:3000>" --batch

```
(ADMIN@kali) ~$ sqlmap -u "http://127.0.0.1:3000" --batch
[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 22:33:57 /2026-04-01/
[22:33:57] [INFO] testing connection to the target URL
[22:33:57] [INFO] checking if the target is protected by some kind of WAF/IPS
[22:33:58] [INFO] testing if the target URL content is stable
[22:33:58] [INFO] target URL content is stable
[22:33:58] [CRITICAL] no parameter(s) found for testing in the provided data (e.g. GET parameter 'id' in 'www.site.com/index.php?id=1'). You are advised to rerun with '--crawl=2'

[*] ending @ 22:33:58 /2026-04-01/
```

Observation:

SQLMap successfully connected to the target, tested content stability, checked WAF/IPS presence, and reported no injectable parameters on the tested endpoint.

9. Anonymous Routing Test Using Tor and Proxychains

Traffic anonymization was tested using Tor and Proxychains.

Commands Used:

```
sudo systemctl start tor
proxychains4 curl ifconfig.me
```

8



Observation:

The scanner identified the HTTP title of the local application, confirming accessibility through Metasploit modules.

11. Binary Analysis Using radare2

A local binary was analyzed for internal structure.

Commands Used:

radare2 /bin/lis

aaa

afl

pdf @ main

```
AKNINIA@KALI: ~/Downloads
$ radare2 /bin/lis
[0x00007f00] aaa
INFO: Relocs has not been applied. Please use '-e bin.relocs.apply=true' or '-e bin.cache=true' next time
INFO: Analyze all flags starting with sym. and entry0 (aa)
INFO: Analyze imports (afaaaa)
INFO: Analyze endpoint (afa entry0)
INFO: Analyze symbols (afaaaa)
INFO: Analyze all functions arguments/locals (afvaaaaF)
INFO: Analyze function calls (aac)
INFO: Analyze 1m bytes of instructions for references (aar)
INFO: Finding and parsing C++ vtables (avrr)
INFO: Analyzing methods (af aa method.+)
INFO: Recovering local variables (afvaaaaF)
INFO: Type matching analysis for all functions (aaft)
INFO: Propagate more return information (aafr)
INFO: Use -AA or aaaa to perform additional experimental analysis
[0x00007f00] afl
0x00004030 1 0 sym.imp.__ctype_toupper_loc
0x00004040 1 0 sym.imp.getenv
0x00004050 1 0 sym.imp.cap.to.text
0x00004060 1 0 sym.imp.fgetfilecon
0x00004070 1 0 sym.imp.sigprocmask
0x00004080 1 0 sym.imp._sprintf_chk
0x00004090 1 0 sym.imp.raise
0x000040a0 1 0 sym.imp._vprintf_chk
0x000040b0 1 0 sym.imp.abort
0x000040c0 1 0 sym.imp._errno_location
0x000040d0 1 0 sym.imp.getfilecon_raw
0x000040e0 1 0 sym.imp.strncmp
0x000040f0 1 0 sym.imp.localtime_r
0x00004100 1 0 sym.imp._exit
0x00004110 1 0 sym.imp.strcpy
0x00004120 1 0 sym.imp._fpending
0x00004130 1 0 sym.imp._flistattr
0x00004140 1 0 sym.imp.isatty
0x00004150 1 0 sym.imp.sigaction
0x00004160 1 0 sym.imp._lscntnl
0x00004170 1 0 sym.imp.localeconv
0x00004180 1 0 sym.imp.faccessat
0x00004190 1 0 sym.imp.readlink
0x000041a0 1 0 sym.imp.fcntl
0x000041b0 1 0 sym.imp.clock_gettime
0x000041c0 1 0 sym.imp.setenv
0x000041d0 1 0 sym.imp.textdomain
0x000041e0 1 0 sym.imp._fclose
0x000041f0 1 0 sym.imp.opendir
0x00004200 1 0 sym.imp.getuid
0x00004210 1 0 sym.imp.bindtextdomain
0x00004220 1 0 sym.imp.dgettext
0x00004230 1 0 sym.imp.__ctype_get_mb_cur_max
0x00004240 1 0 sym.imp.strlen
0x00004250 1 0 sym.imp._stack_chk_fail
0x00004260 1 0 sym.imp.getopt_long
0x00004270 1 0 sym.imp.freecon
0x00004280 1 0 sym.imp.stchr
```




```
AKNINIA@KALI: ~/Downloads
$ gdb /main.o
GNU gdb (Debian 10.3-2) 10.3
Copyright (C) 2024 Free Software Foundation, Inc.
License GPLv3+: GNU GPL version 3 or later <http://gnu.org/licenses/gpl.html>
This is free software: you are free to change and redistribute it.
There is NO WARRANTY, to the extent permitted by law.
Type "show copying" and "show warranty" for details.
This GDB was configured as "x86_64-linux-gnu".
Type "show configuration" for configuration details.
For bug reporting instructions, please see:
<https://www.gnu.org/software/gdb/bugs/>.
Find the GDB manual and other documentation resources online at:
<http://www.gnu.org/software/gdb/documentation/>.

For help, type "help".
Type "apropos word" to search for commands related to "word"...
Reading symbols from /bin/ls...
(No debugging symbols found in /bin/ls)
(gdb) info functions
(gdb) info functions
All defined functions:

Non-debugging symbols:
0x0000000000000000 __ctype_toupper_loc@plt
0x0000000000000000 __getenv@plt
0x0000000000000000 cap_to_text@plt
0x0000000000000000 getfilecon@plt
0x0000000000000000 sigprocmask@plt
0x0000000000000000 __snprintf_chk@plt
0x0000000000000000 raise@plt
0x0000000000000000 __vfprintf_chk@plt
0x0000000000000000 abort@plt
0x0000000000000000 __errno_location@plt
0x0000000000000000 getfilecon_raw@plt
0x0000000000000000 strncmp@plt
0x0000000000000000 localtime_r@plt
0x0000000000000000 _exit@plt
0x0000000000000000 strcpy@plt
0x0000000000000000 __fpending@plt
0x0000000000000000 flistxattr@plt
0x0000000000000000 lstat@plt
0x0000000000000000 sigaction@plt
0x0000000000000000 inwcntrl@plt
0x0000000000000000 localeconv@plt
0x0000000000000000 faccessat@plt
0x0000000000000000 readlink@plt
0x0000000000000000 fcntl@plt
0x0000000000000000 clock_gettime@plt
0x0000000000000000 setenv@plt
0x0000000000000000 textdomain@plt
0x0000000000000000 fdopen@plt
0x0000000000000000 opendir@plt
0x0000000000000000 getpwuid@plt
0x0000000000000000 bindtextdomain@plt
0x0000000000000000 dcgettext@plt
0x0000000000000000 __ctype_get_mb_cur_max@plt
0x0000000000000000 strlen@plt
0x0000000000000000 ... with full name:
```

Observation:

Function symbols and exported routines were successfully displayed.

13. Conclusion

This task demonstrated practical use of multiple cybersecurity tools across different phases of security assessment, including reconnaissance, scanning, vulnerability analysis, SQL testing, anonymized routing, exploitation framework usage, and binary inspection.

The activity provided practical understanding of how multiple tools integrate into a complete penetration testing workflow.